Suspicious Account Compromise Investigation

Splunk • Windows Security Events • SOC Triage • Incident Escalation

Prepared by Marcos Rivera

Case Overview
This simulated SOC investigation follows a suspected password-spraying campaign that progressed into privileged account compromise, post-login discovery, persistence, privilege escalation, sensitive payroll access, and possible data exfiltration. The exercise demonstrates SPL querying, Windows event interpretation, timeline reconstruction, evidence-based reasoning, MITRE ATT&CK mapping, and escalation writing.

Objectives

- Identify suspicious authentication patterns using SPL.
- Correlate authentication events with Windows Security Event logs.
- Build a chronological attack timeline and distinguish confirmed evidence from hypotheses.
- Recognize discovery, persistence, and privilege-escalation behaviors.
- Produce concise Tier 1 escalation notes using Summary → Assessment → Recommendation.

Phase 1 — Initial Authentication Alert

Alert: Multiple failed authentication attempts from 185.44.10.9 between 14:01 and 14:10. Severity: Medium.

```
14:01 user=admin   status=failure src_ip=185.44.10.9
 14:02 user=admin   status=failure src_ip=185.44.10.9
 14:03 user=admin   status=failure src_ip=185.44.10.9
 14:04 user=jsmith  status=failure src_ip=185.44.10.9
 14:05 user=payroll status=failure src_ip=185.44.10.9
 14:06 user=admin   status=success src_ip=185.44.10.9
 14:08 user=guest   status=failure src_ip=10.0.0.21
 14:09 user=jsmith  status=success src_ip=10.0.0.14
```

SPL Query

```
status=failure | stats count by src_ip | where count > 2 | sort - count | table
src_ip count
```

My Investigation Response

The failures spread across the admin, jsmith, and payroll accounts from the same source IP within roughly five minutes, which suggests password spraying. The guest failure could be benign, while jsmith successfully authenticates from a different 10.0.0.x address on the first attempt. That difference increases suspicion around 185.44.10.9, although the normal network range should be verified before drawing a firm conclusion. I would investigate the successful admin login at 14:06 and review all activity during that session, specifically looking for account creation, privilege changes, and outbound connections. I would document the findings and escalate the suspected compromise to Tier 2.

Analyst Takeaway

The initial alert is consistent with password spraying because a single source IP targets multiple accounts. The successful admin authentication from the same source substantially raises the severity and justifies deeper host-level investigation.

Phase 2 — Post-Login Discovery

```
14:06 EventCode=4624  Account_Name=admin  Source_Network_Address=185.44.10.9
Workstation_Name=FINANCE-01
 14:07 EventCode=4688  Account_Name=admin  New_Process_Name=powershell.exe
Creator_Process_Name=cmd.exe
 14:08 EventCode=4688  Account_Name=admin  New_Process_Name=whoami.exe
Creator_Process_Name=powershell.exe
 14:09 EventCode=4688  Account_Name=admin  New_Process_Name=net.exe
CommandLine="net user"
 14:10 EventCode=4688  Account_Name=admin  New_Process_Name=net.exe
CommandLine="net localgroup administrators"
```

My Investigation Response

A supposed admin login was successful, PowerShell launched, and an identity check using whoami followed. The session then listed users with net user and checked local administrator membership. I would investigate whether any additional actions occurred during this session and immediately look for newly created accounts. Listing users and privileges directly after a suspicious login is a red flag because threat actors commonly perform discovery to understand

available accounts and privileged access. I would continue the timeline and escalate the potential compromise to Tier 2.

Escalation Note

Summary: A successful admin logon from 185.44.10.9 was followed by PowerShell execution, an identity check, user enumeration, and enumeration of local administrators.

Assessment: The sequence is suspicious because discovery activity occurred immediately after authentication and is consistent with an actor attempting to understand the compromised host and identify privileged access.

Recommendation: Review the remainder of the admin session for account creation, privilege changes, persistence mechanisms, suspicious process execution, and outbound network activity. Escalate to Tier 2 for potential account compromise.

Phase 3 — Persistence and Privilege Escalation

```
14:12 EventCode=4720  Subject_Account_Name=admin
Target_Account_Name=svc_support  Computer=FINANCE-01
 14:13 EventCode=4732  Subject_Account_Name=admin       Member_Name=svc_support
Group_Name=Administrators
 14:14 EventCode=4624  Account_Name=svc_support
Source_Network_Address=185.44.10.9  Workstation_Name=FINANCE-01
```

My Investigation Response

This makes the previous assessment more sound. A new account, svc_support, was created and added to the Administrators group, giving it elevated privileges. The new account then successfully logged on from the same suspicious IP. This needs to be brought to the attention of a more seasoned analyst immediately. My next step would be to document the findings and build a complete timeline of every action performed during the svc_support session. In MITRE ATT&CK terms, the earlier account and privilege enumeration reflects Discovery, while the account creation supports Persistence and the administrator-group addition reflects Privilege Escalation.

Escalation Note

Summary: The compromised admin account created svc_support, added it to the local Administrators group, and the newly created account then authenticated successfully from the same suspicious source IP.

Assessment: The activity provides strong evidence of persistence and privilege escalation following the initial compromise. Combined with the earlier discovery behavior, the incident is consistent with an attacker establishing continued privileged access to FINANCE-01.

Recommendation: Escalate immediately to Tier 2 or incident response, preserve the event timeline, investigate all svc_support activity, and review additional hosts for use of the same account or source IP.

Phase 4 — Sensitive Data Access and Possible Exfiltration

```
14:16 EventCode=4688  Account_Name=svc_support  New_Process_Name=cmd.exe
Creator_Process_Name=powershell.exe
 14:17 user=svc_support action=file_access file=C:\Finance\employee_payroll.xlsx
 14:18 user=svc_support action=file_export file=C:\Finance\employee_payroll.xlsx
 14:19 host=FINANCE-01 action=outbound_connection dest_ip=203.0.113.88
dest_port=443 process=powershell.exe
 14:21 user=svc_support action=logout status=success
```

My Investigation Response

The svc_support account had privileges that allowed it to access sensitive employee payroll information. The account accessed and exported employee_payroll.xlsx, and the host then communicated with an unknown external IP address before the account logged out. The logs confirm access and export of the sensitive document, but they do not prove that the payroll file was actually transmitted to the external IP. I would treat this as possible data exfiltration and seek additional network or proxy evidence before claiming confirmed theft.

Final Escalation Note

Summary: The newly created privileged account svc_support accessed and exported employee_payroll.xlsx, then established an outbound HTTPS connection from FINANCE-01 to 203.0.113.88 before logging out.

Assessment: The activity is consistent with potential data exfiltration following account compromise, persistence, and privilege escalation. Sensitive payroll data was confirmed to have been accessed and exported; however, the available logs do not prove that the exported file was transmitted to the external destination.

Recommendation: Escalate to Tier 2 or incident response, preserve the complete event timeline, investigate the destination IP and outbound traffic, review proxy/network telemetry for

evidence of file transfer, examine svc_support activity across additional systems, and follow organizational containment procedures.

Consolidated Attack Timeline

Time	Evidence	Observed Activity	Interpretation
14:01–14:05	Authentication	Multiple accounts receive failures from 185.44.10.9	Potential password spraying
14:06	4624	admin successfully logs in from 185.44.10.9	Suspected account compromise
14:07–14:10	4688	PowerShell, whoami, net user, local administrators enumeration	Discovery
14:12	4720	svc_support account created	Persistence
14:13	4732	svc_support added to Administrators	Privilege Escalation
14:14	4624	svc_support logs in from same suspicious IP	Persistence validated / continued access
14:17–14:18	File activity	Payroll file accessed and exported	Actions on sensitive data
14:19	Network	Outbound HTTPS connection to 203.0.113.88	Possible exfiltration / external communication
14:21	Session	svc_support logs out	End of observed session

MITRE ATT&CK Behaviors Demonstrated

Discovery: whoami, net user, and net localgroup administrators were used to learn the current identity, enumerate accounts, and identify privileged users.

Persistence: A new account, svc_support, was created to establish additional access.

Privilege Escalation: svc_support was added to the local Administrators group.

Collection / Exfiltration Concern: Sensitive payroll information was accessed and exported, followed by an outbound connection. Additional telemetry would be required to prove transmission of the file.

Skills Demonstrated

- Splunk Search Processing Language (SPL): filtering, stats, where, sort, and table.

- Windows Security Event analysis: 4624, 4688, 4720, and 4732.
- Authentication-pattern analysis and password-spraying identification.
- Timeline reconstruction and host/user correlation.
- MITRE ATT&CK behavioral mapping.
- Evidence-based incident assessment and uncertainty management.
- Tier 1 SOC escalation writing and investigation handoff.

Final Case Conclusion

The investigation began with a medium-severity authentication alert and progressed into a high-confidence account-compromise case. Correlation of authentication activity, Windows Security events, process execution, account creation, privilege changes, file activity, and outbound network telemetry revealed a coherent attack sequence. The evidence supports suspected password spraying followed by privileged account compromise, host discovery, persistence, privilege escalation, and access to sensitive payroll data. Possible exfiltration is suspected but not confirmed because the available logs do not establish that the exported file was transmitted to the external destination. The appropriate Tier 1 action is immediate escalation with a preserved timeline and clear recommendations for containment and deeper network investigation.

Portfolio Note

This project is a simulated training lab created to demonstrate SOC analyst investigation methodology. All users, IP addresses, hosts, files, and events are fictional and used for educational